CIA TRIAD + EXTENDED PROPERTIES

- **Confidentiality:** Only authorised users can re…
- **Integrity:** Data not changed without permission
- **Availability:** System accessible when needed
- **Authenticity:** Verify the entity is genuine
- **Accountability:** Actions traceable to a person
- **Non-repudiation:** Cannot deny having done it

Attacks:
DoS/DDoS -> Availability
MitM -> Confidentiality+Integrity

ACCESS CONTROL — DAC / MAC / RBAC / ABA

DAC Rules (Crib Sheet p.1):

- **R2** `grant {a} to S,X` — "owner" in A[S0,X]
- **R3** `delete a from S,X` — "owner" OR "control" in A[S0,X]
- **R5** `create object X` — None -> stores owner
- **R7** `create subject S` — None -> stores control
- **R8** `destroy subject S` — "owner" in A[S0,S]

Policy comparison:

Model	Decides	Flex	Best for
DAC	Owner	High	Files

AUTHENTICATION — KNOW / HAVE / ARE / WH

- **KNOW** Password, PIN, security Q — Risk: Phishing, guessing
- **HAVE** Smart card, OTP, phone — Risk: Lost/stolen
- **ARE** Fingerprint, iris, gait — Risk: FAR/FRR errors
- **WHERE** Location/GPS/terminal — Risk: VPN bypass

FAR=false accept | FRR=false reject | CER=crossove…
Attacks: Dictionary | Brute force | Rainbow table -> S…

RSA — EVERY YEAR — HIGH PRIORITY

Key Generation (Crib Sheet p.3):

1. `n = p x q` (p, q prime)
2. `phi(n) = (p-1)(q-1)`
3. `e: gcd(phi(n),e)=1, 1<e<phi(n)`
4. `d: d*e mod phi(n) = 1` (use EEA)

```
Public:{e,n}   Private:{d,n}
Encrypt: C = M^e mod n
Decrypt: M = C^d mod n
```

EEA — find d (two phases):

Phase 1 — Divide down, save remainders:

```
phi(n) = q1*e + r1   -> r1 = phi(n)-q1…
     e = q2*r1+ r2   -> r2 = e-q2*r1
    r1 = q3*r2+ r3   -> r3 = r1-q3*r2
Stop when remainder=0. If r=1: gcd=1,…
```

Phase 2 — Back-substitute upwards:

```
1 = r_{n-1} - q * r_{n-2}
Replace each r with saved equation ab…
Until: 1 = A*e + B*phi(n)
d = A mod phi(n)    Verify: e*d mod ph…
```

Repeated squaring for M=C^d mod n:

```
1. Write d in binary: e.g. 113=64+32+…
2. Build: C^1,C^2,C^4,C^8... (square …
3. Multiply powers matching 1-bits   m…
```

Brute force:
`Time = 2^keysize / speed`

DIFFIE-HELLMAN KEY EXCHANGE

Public: prime q, primitive root a (a < q)

```
Alice: YA = a^XA mod q   (XA private)
Bob:   YB = a^XB mod q   (XB private)
Key K = YB^XA mod q = YA^XB mod q
```

Weakness: MitM intercepts YA/YB, substitutes …
Fix: Authenticated DH with digital certificates

DES vs AES + FEISTEL (Crib Sheet p.2)

Property	DES	AES
Block	64 bits	128 bits
Key	56bit (BROKEN)	128/192/256
Rounds	16	10/12/14
Type	Feistel	NOT Feistel

Feistel: `L_i=R_{i-1}  R_i=L_{i-1} XO…`
Invertible: R0=L1 L0=R1 XOR F(K1,L1) [F need not …

CBC vs ECB (Crib Sheet p.3 diagram)

ECB — WEAK: same P_i -> same C_i. Pattern…
`C_i = E(K, P_i)`

CBC — SECURE, use this
```
Encrypt: C_i = E(K, P_i XOR C_{i-1})
         C_0 = IV  (fresh random per …
Decrypt: P_i = D_K(C_i) XOR C_{i-1}
```
Error: corrupt C_i ruins ONLY P_i and P_{i+1}

Worked Example (2025Q3 / 2024Q9 style):
P1=1101 P2=0110 P3=1001 | IV=1010 Key=0011 …

- **Blk1:** `1101 XOR 1010=0111  0111 XOR 0011= 0`
- **Blk2:** `0110 XOR 0100=0010  0010 XOR 0011= 0`
- **Blk3:** `1001 XOR 0001=1000  1000 XOR 0011= 1`

`Ciphertext: 0100  0001  1011`

Hex <-> Binary (Crib Sheet p.4):

`0 1 2 3 4 5 6 7`
`8 9 A B C D E F`

RC4 STREAM CIPHER (Crib Sheet p.3)

Init: S[i]=i; T[i]=K[i mod keylen] for i=0..255
KSA: `j=(j+S[i]+T[i]) mod 256; Swap(…`
PRGA: generate keystream byte k; ciphertext=pl…
Insecure: KSA invariance -> biased output -…
Exam: show S-array state after each KSA iteration

SSO + KERBEROS (every year)

CIAAN under SSO:

- ✓ **Confidentiality:** Fewer credential transmiss…
- ✓ **Integrity:** Tickets cryptographically signed
- ✗ **Availability:** SINGLE POINT OF FAILURE
- ✓ **Authenticity:** KDC verifies identity once
- ✓ **Accountability:** Central audit log
- ✓ **Non-repudiation:** Tied to verified identity

Kerberos 5 Steps:

1. User->AS: username (plaintext), request TGT
2. AS->User: TGT(enc.TGS key)+session key(en…
3. User->TGS: TGT + Authenticator (prevents re…
4. TGS->User: Service Ticket (enc. service key)
5. User->Service: Ticket+Authenticator -> access

Tickets encrypted with RECIPIENT key. User cannot f…

WEB SECURITY — SQL / CSRF / XSS

HTTP vs HTTPS:
HTTP (80): plaintext — passwords visible on net…
HTTPS (443): TLS encrypt + CA cert + integrity …
SSL deprecated. TLS is current standard. Always use…

SQL Injection — Malicious SQL bypasses auth…
`Atk: u=' OR 1=1 --  (1=1 always true,…`
`Normal: WHERE u='alice' AND p='x'  -> a…`
Fix: Parameterised queries (prepared statements)

CSRF — Evil site fires request using victim's acti…
`Victim logged in to bank, visits evil…`
`Evil.com sends POST to bank using victi…`
Fix: CSRF tokens | SameSite cookie attribute

XSS — Injected JS runs in victim's browser.
`Stored: script in DB, runs for every …`
`Reflected: script in URL echoed by serv…`
Fix: HttpOnly cookies | CSP headers | sanitise

DIGITAL FORENSICS — 4 STEPS

1. **Seizure:** Isolate. DO NOT power off (RAM = … — BIOS time, photos, chain of custody log.
2. **Acquisition:** Write blocker + bit-for-bit copy (… — SHA-256 hash. Never touch original.
3. **Analysis:** Registry, browser history, deleted f… — Work ONLY on verified copies. Timeline.
4. **Reporting:** Formal report. Hash values. Tool… — Chain of custody. Court admissible.

OSI MODEL — ATTACKS PER LAYER

Layer	Attack
7 Application	SQL Injection, XSS, CSRF
4 Transport	SYN Spoofing (TCP 3-way hand…
3 Network	IP Spoofing, routing attacks
2 Data Link	ARP Poisoning (LAN)
1 Physical	Wiretapping, fibre tapping

Active: Modifies/disrupts (DoS, MitM, spoofing)
Passive: Only listens, no changes (fibre tapping)